

BÁO CÁO TIẾN ĐỘ THỰC HIỆN ĐỒ ÁN

BUỔI TRÌNH BÀY 23/04

1. Mục tiêu tổng quát và các mục tiêu cụ thể

Mục tiêu tổng quát: Xây dựng một hệ thống bảo vệ người dùng trước các cuộc tấn công lừa đảo (phishing) thông qua URL bằng cách kết hợp học máy và phân tích nội dung thời gian thực.

- Phát hiện URL lừa đảo với độ chính xác trên 99% bằng mô hình XGBoost.
- Triển khai dưới dạng Chrome Extension hoạt động hoàn toàn offline để bảo vệ quyền riêng tư.
- Xây dựng kiến trúc phòng thủ đa tầng để giảm thiểu tối đa tỉ lệ báo động giả (False Positive).

2. Phạm vi triển khai

Hệ thống triển khai dưới dạng tiện ích mở rộng (Extension) trên trình duyệt Google Chrome theo chuẩn Manifest V3. Phạm vi nghiên cứu tập trung vào phân tích ngữ vựng URL (39 đặc trưng) và phân tích cấu trúc DOM trang web. Việc triển khai trên trình duyệt giúp can thiệp và cảnh báo người dùng ngay tại thời điểm truy cập (Real-time).

Lý do lựa chọn phạm vi này:

- Manifest V3 đảm bảo hiệu suất cao và bảo mật tốt hơn so với V2.
- Phân tích URL + DOM đủ nhẹ để chạy offline trên trình duyệt mà vẫn đảm bảo độ chính xác.
- Tiếp cận Real-time giúp chặn đứng tấn công ngay khi người dùng vừa truy cập.

3. Đối tượng phục vụ và giá trị ứng dụng

Đối tượng:

- Người dùng internet phổ thông, đặc biệt là nhóm người dùng không có kiến thức chuyên sâu về ATTT.

Bối cảnh:

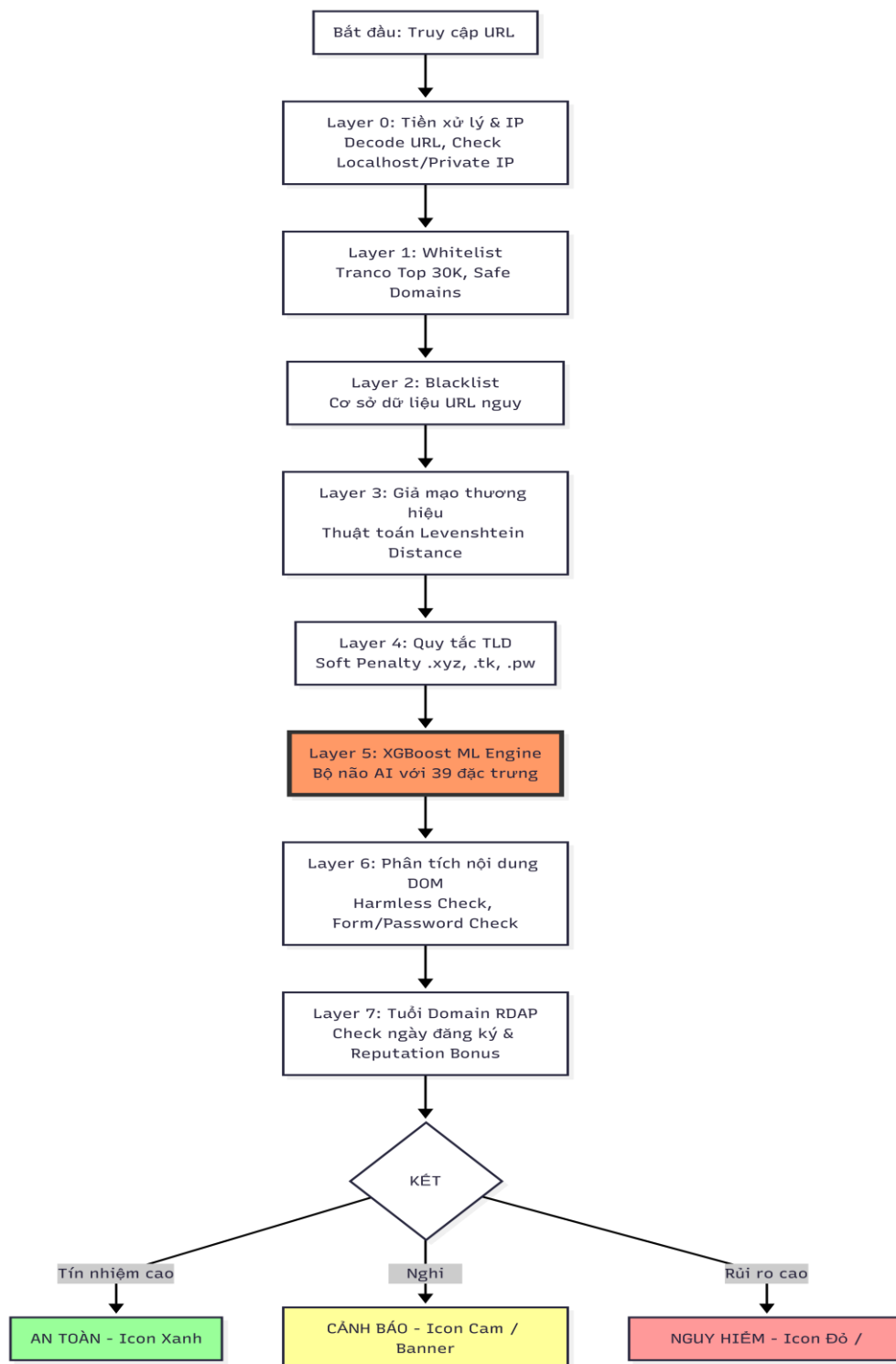
- Sự bùng nổ của các trang web giả mạo ngân hàng, ví điện tử, và mạng xã hội.

Giá trị ứng dụng:

- Cảnh báo tức thì bằng trực quan (Banner/Icon/Popup), hoạt động nhẹ nhàng.
- Bảo vệ quyền riêng tư tuyệt đối nhờ hoạt động hoàn toàn offline.

4. Mô hình thực nghiệm chính (Pipeline hệ thống)

Hệ thống được thiết kế theo kiến trúc phòng thủ 8 lớp (Defense in Depth), kết hợp giữa danh sách tin cậy, quy tắc chuyên gia và học máy.



Hình 1: Quy trình xử lý URL qua Pipeline 8 lớp phòng thủ

Chi tiết kỹ thuật các lớp phòng thủ:

- Lớp 0-2 (Lọc nhanh): Giải mã URL đa vòng, nhận diện IP nội bộ và tra cứu Whitelist (Tranco 30K) / Blacklist.

- Lớp 3-4 (Heuristic): Sử dụng thuật toán Levenshtein phát hiện Typosquatting và Soft Penalty cho TLD đáng ngờ (.xyz, .tk).

TLD: viết tắt của top-level domain, là phần đuôi url. kẻ tấn công thường dùng tld giá rẻ (.xyz, .tk) để ẩn danh.

- Lớp 5 (Core Engine): Mô hình XGBoost phân tích 39 đặc trưng ngữ vựng để tính toán xác suất lừa đảo.
- Lớp 6-7 (Hậu xử lý): Phân tích DOM (Harmless Check) và tuổi domain (RDAP) để hiệu chỉnh điểm số AI.

5. Các bước triển khai đã thực hiện

Bước 1: Thu thập dữ liệu (Chạy script 01_collect_data.py)

sử dụng thư viện requests để tải phishtank_raw.csv (url báo cáo) và tranco_raw.csv (url uy tín có rank). gộp thành combined_dataset.csv bằng pandas.

Tăng cường dữ liệu (Data Augmentation)

chạy script 01a_augment_brand_data.py để trộn thương hiệu, keyword và tld rác. giúp model nhận diện các trang lừa đảo mới (zero-day) dựa trên quy luật cấu trúc.

Chuẩn hóa Dataset (Quy trình 4 bước)

- Làm sạch & Chuẩn hóa: Loại bỏ trùng lặp, hạ chữ thường, xóa fragment.
- Xử lý mất cân bằng: Dùng SMOTE (tạo mẫu giả) và Undersampling (cắt bớt mẫu thực) để đưa tỷ lệ về 1:1.

smote giúp model thấy nhiều biến thể lừa đảo hơn, tránh học thuộc lòng.

undersampling giúp tập dữ liệu gọn nhẹ, học nhanh hơn.

- Scaling: Đồng bộ thang đo đặc trưng bằng StandardScaler.

Bước 2: Trích xuất đặc trưng (Chạy script 02_feature_extraction_v3.py)

biến url thành 39 con số đặc trưng (độ dài, ký tự đặc biệt, entropy, levenshtein). kết quả là file features_v4.csv.

entropy là độ nhiễu URL ví dụ: vietcombank.com.vn/ngan-hang-so và login-update.b2x9z.xyz/token=%A3%F9%8B...

levenshtein là thuật toán so sánh url có chứa ký tự bị cố tình gõ sai chính tả với url gốc.

Bước 3: Huấn luyện model (Chạy script 03_train_model_v4.py)

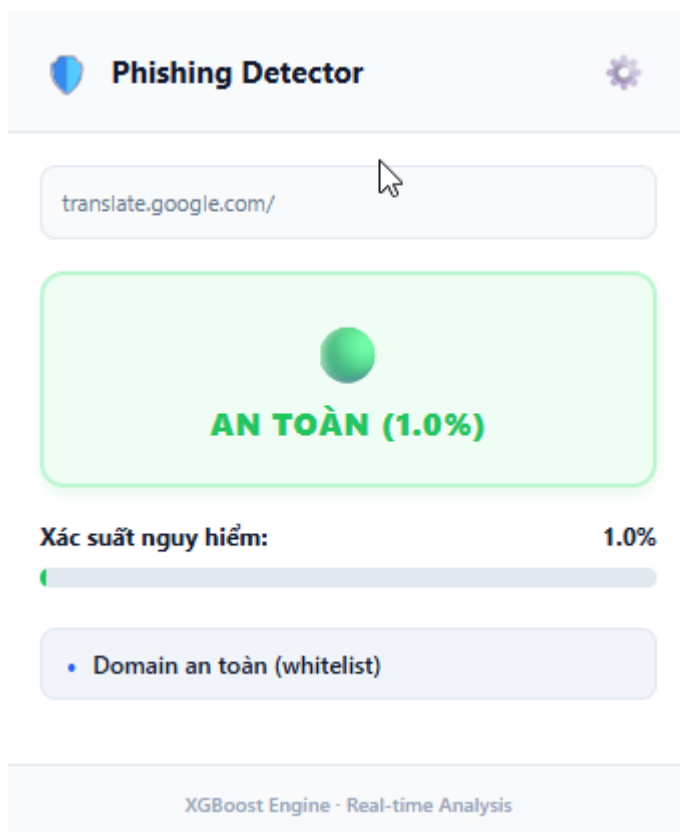
huấn luyện mô hình xgboost và tối ưu siêu tham số. xuất ra file xgboost_model_v4.json để triển khai nhẹ trên trình duyệt.

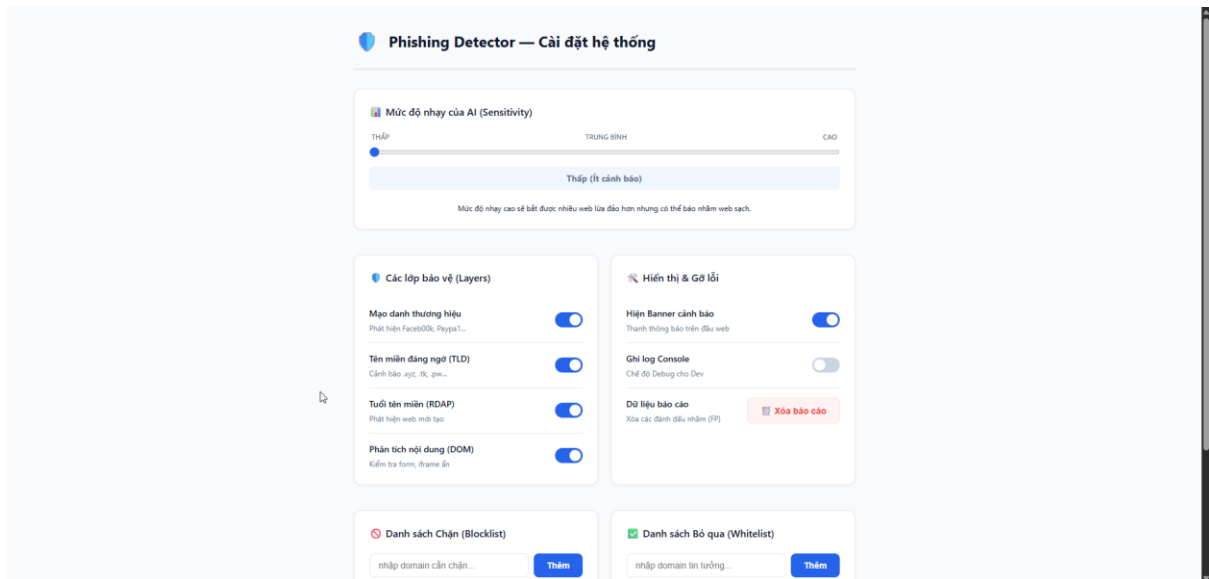
Bước 4: Danh sách trắng (Chạy script 04_prepare_tranco_top30k.py)

nén 30.000 tên miền uy tín vào tranco_top30k.json giúp extension phản hồi tức thì mà không cần hỏi model.

Bước 5: Phát triển Extension (Javascript)

chi tiết kỹ thuật: xgboost_predictor.js thực hiện suy luận. content_analyzer.js check harmless page (giảm 70% rủi ro nếu trang không có form).





6. Kết quả thực nghiệm hiện tại

Mô hình XGBoost đạt F1-Score 0.9952 trên tập kiểm thử.

F1-Score là trung bình điều hòa giữa Precision và Recall. Đây là chỉ số khắt khe buộc mô hình phải tối ưu cả việc bắt đúng và không bỏ lọt nghi phạm.

Extension đã vượt qua bài kiểm thử 105 URL thực tế với tỷ lệ chính xác 100%, độ trễ < 5ms.

Bảng 3.3. Kết quả kiểm thử toàn diện 105 URL trên Chrome Extension

Nhóm URL	Số lượng	Kết quả	Ghi chú
Domain chính thức (google.com, github.com, ...)	19	19/19 ✓	Zero false positives
Tranco Top 30K có path (google.com/search, ...)	16	16/16 ✓	Không flag URL hợp lệ
Site giả mạo FitGirl (fake .com/.org/.net)	20	20/20 ✓	Tăng từ 50% → 100%
Typosquatting thương hiệu (paypal, goggle, ...)	16	16/16 ✓	Levenshtein phát hiện
Phishing với TLD đáng ngờ + từ khóa	18	18/18 ✓	Rule-based 97%
Edge case (IP riêng, homograph, encoding)	16	16/16 ✓	Ba kỹ thuật né tránh
TỔNG	105	105/105 (100%)	Hoàn hảo

7. Khó khăn đã gặp và cách xử lý

Khó khăn 1:

- Báo động nhầm cao trên một số trang giải trí trung quốc do URL chứa ký tự nằm trong blacklist.
- Xử lý: Triển khai Layer 6 (Harmless Page Check) - Trang không có form/input thì giảm 70% rủi ro.
- Kể cả thương hiệu như google.com đôi khi cũng bị flag là mất an toàn.

Khó khăn 2:

- Lỗi kết nối RDAP khi check tuổi domain quốc tế.
- Xử lý: Sửa API RDAP, thêm Timeout 10s và Reputation Bonus (cộng điểm cho TLD .vn, .eu, .ru.....).

8. Phần đã hoàn thành và kế hoạch

Đã hoàn thành:

- Nhân dự đoán ML (39 features), 8 lớp phòng thủ, Giao diện và Hệ thống báo cáo.

Đang thực hiện:

- Hoàn thiện bản thảo quyền báo cáo đồ án.

Kế hoạch tiếp theo:

- Chuẩn bị demo và sửa bài báo cáo